The House With no Curtains

A small online shop keeps customer credit card numbers in a spreadsheet on a shared computer, visible to anyone who walks by, with no password protecting it. Using the CIA Triad and the AAA framework, list everything wrong with this picture and which principle each fix would restore.

1. Credit card numbers sit in plain text in a spreadsheet. This breaks **Confidentiality**. Anyone who opens the file can read every number. The fix is to encrypt the file or, better, stop storing card numbers and use a payment processor that tokenizes them. That restores **Confidentiality**.

2. The screen is visible to anyone who walks by. This also breaks **Confidentiality**, through physical exposure. The fix is to auto-lock the screen, move the computer out of public view, and restrict who can get near it. That restores **Confidentiality**.

3. There is no password on the file. This breaks **Confidentiality** and **Authentication**, because nothing checks who is opening it. The fix is to password-protect the file and add a strong login with MFA. That restores **Authentication**, which in turn supports **Confidentiality**.

4. The computer is shared, so no one has their own identity. This breaks **Authentication** and **Accounting**, since you can't tell who is who. The fix is to give each person a unique account. That restores **Authentication**.

5. Anyone who can open the file can do anything with it. This breaks **Authorization**. The fix is least privilege: only staff who truly need card data get access, and read-only where possible. That restores **Authorization**.

6. There is no record of who opened, copied, or changed anything. This breaks **Accounting**. The fix is to turn on access and change logs and review them regularly. That restores **Accounting**.

7. Anyone can edit or delete entries without detection. This breaks **Integrity**. The fix is read-only permissions, version history, and change tracking. That restores **Integrity**.

8. There is one copy on one shared machine, with no backup. This breaks **Availability**, because a crash, theft, or accidental deletion could wipe out the data. The fix is regular encrypted backups kept off the machine. That restores **Availability**.

Activity: Asset, Threat, Vulnerability, and Risk Mapping

Object/Place Chosen: A personal phone

Asset: The student's personal data, financial accounts, and digital identity stored on the phone, including photos, contacts, messages, e-wallet and banking apps, and social media accounts.

Threat: A thief or opportunistic individual who steals or finds the unattended phone, or who watches the owner enter their passcode in a public place, in order to unlock the phone and access its contents.

Vulnerability: Using a weak or missing screen lock (such as 1234 or a birthday) while carrying and using the phone in crowded public places like jeepneys and malls.

Risk: Unauthorized access to the owner's accounts and private data, resulting in financial loss, account hijacking, and identity theft.

Risk Statement: Using a weak or missing screen lock on a phone in crowded public places creates a vulnerability that a thief can exploit to unlock the device, access the owner's e-wallet, accounts, and private data, and cause financial loss and identity theft.